

Project Comprehensive Guide: BEC Phishing Detection

Team: Akash Basak, Abhiraj Kumar Rajak, Subhamita Mondal

Project: Diploma 5th Semester (Cyber Forensics & Information Security)

1. Project Roles & Responsibility Breakdown

To ensure a smooth presentation, each member should be the "Subject Matter Expert" for their specific modules while understanding the overall pipeline.

Akash Basak: Lead Developer & Data Analysis

- **Module Ownership:** `train_model.py` and `predict_email.py`.
- **Key Tasks:** * Implemented the **Random Forest Classifier**.
 - Tuned the **Class Weights (5:1)** to prioritize Recall over Precision.
 - Developed the real-time prediction script to handle unseen data.
 - Analyzed the Confusion Matrix and performance metrics.

Abhiraj Kumar Rajak: Feature Engineering & Documentation

- **Module Ownership:** `feature_engineer.py` and Project Reporting.
- **Key Tasks:** * Designed the **One-Hot Encoding** logic for categorical variables.
 - Managed the mapping between raw simulated data and model-ready vectors.
 - Maintained the project documentation and technical references.
 - Collaborated on the logic for the `urgency_score` and `sender_anomaly` definitions.

Subhamita Mondal: System Architecture & Testing

- **Module Ownership:** `data_simulator.py` and `README.md`.
- **Key Tasks:** * Built the **Synthetic Data Generator** using NumPy and Pandas.
 - Defined the statistical distributions (Beta & Poisson) for realistic simulation.
 - Validated the system architecture and handled environmental setup (Virtual Env/Git).
 - Conducted unit testing to ensure data consistency between modules.

2. Technical Topic Summary

The Core Problem: Why ML for BEC?

Traditional security systems use "signatures" (looking for known bad files or links). **Business Email Compromise (BEC)** is "payload-less"—it uses only text and psychology. Our project uses ML to detect the *behavior* of the attacker (urgency, spoofing, financial intent) rather than just searching for a virus.

The Algorithm: Random Forest

- **What it is:** An ensemble of many Decision Trees.
- **Why we chose it:** It handles non-linear relationships well (e.g., high urgency is only suspicious *if* it's also a financial request). It is also less likely to "overfit" compared to a single decision tree.

The Metric: Recall vs. Precision

- **The Trade-off:** In most ML, we want high accuracy. In Cybersecurity, we want high **Recall**.
- **Why?** A "False Positive" means a safe email is flagged (annoying but safe). A "False Negative" means an attack got through (catastrophic). Our 5:1 weight ensures we catch the attacks.

3. Viva-Voce Preparation (Possible Questions)

Category A: General & Conceptual

1. **Q: What is the difference between Phishing and BEC?**
 - A: Phishing is usually a broad attack with links/malware. BEC is a targeted attack (whaling) using social engineering and impersonation to steal money or data.
2. **Q: Why use synthetic data instead of real emails?**
 - A: Real corporate emails contain PII (Personally Identifiable Information) and sensitive financial data. For a prototype, synthetic data allows us to model attack patterns safely.

Category B: Technical (Python & ML)

3. **Q: What is One-Hot Encoding and why did you use it?**
 - A: ML models only understand numbers. One-Hot Encoding converts categories (like "Wire Transfer") into binary columns (1s and 0s) so the model doesn't think one category is "larger" than another.
4. **Q: Why did you use Random Forest instead of a simpler model like Logistic Regression?**
 - A: BEC indicators interact in complex ways. Random Forest captures these interactions through multiple trees, whereas Logistic Regression assumes more linear relationships.
5. **Q: How do you handle a "Confidence Score" in your prediction?**
 - A: We use `model.predict_proba()`. This doesn't just give a 1 or 0; it tells us the percentage of trees in our forest that voted "Malicious."

Category C: Forensics & Security

6. **Q: What is "Typosquatting" and how do you detect it?**

- A: It's registering a domain similar to a real one (e.g., `microsoft.com`). We use the `domain_similarity_score` to detect how close the sender's domain is to a known trusted domain.
7. **Q: If the model flags a legitimate email as malicious (False Positive), what is the recovery process?**
- A: The system acts as a "Decision Support" tool. The email should be moved to a quarantine folder where a human analyst can verify the sender via an out-of-band channel (like a phone call).

4. Project File Checklist for Demo

1. **Virtual Env:** Ensure `.venv` is active.
2. **Data:** Run `data_simulator.py` to show you can generate data on the fly.
3. **Training:** Run `train_model.py` to show the Confusion Matrix plot.
4. **Prediction:** Run `predict_email.py` to show the "Red Alert" for a suspicious input.